

Cloud Security Alliance (CSA) Security Guidance for Critical Areas of Cloud Computing

Page 1 of 3 | Document ID: doc_en_08

Domain 1: Cloud Architecture, Service Models, and Shared Responsibility

The cloud reference model defines three service models: Infrastructure as a Service (IaaS), PaaS, and Software as a Service (SaaS).

The Shared Responsibility Model delineates security obligations between the cloud service provider and the tenant customer.

In IaaS, the customer retains responsibility for the guest OS, runtime, applications, identity configuration, and data protection.

In SaaS, the provider manages the entire technology stack, while the customer remains solely responsible for identity access and data protection.

Cloud Security Alliance (CSA) Security Guidance for Critical Areas of Cloud Computing

Page 2 of 3 | Document ID: doc_en_08

Domain 11: Cryptography, Key Management, and Bring Your Own Key (BYOK)

Tenants processing regulated workloads must maintain control of cryptographic keys using Bring Your Own Key (BYOK) architecture.

Cryptographic keys must be generated and stored inside Dedicated Hardware Security Modules (HSM) certified to FIPS 140-2.

Tenant encryption keys must never be exported in plaintext outside the boundary of the validated hardware security module.

Automated key rotation policies must cycle data encryption keys at least annually to limit cryptographic exposure windows.

Cloud Security Alliance (CSA) Security Guidance for Critical Areas of Cloud Computing

Page 3 of 3 | Document ID: doc_en_08

Domain 12: Identity, Access Management, and Zero Trust Architecture

Zero Trust Network Access (ZTNA) principles mandate that no entity or connection is inherently trusted based on network perimeter.

All access requests must be explicitly authenticated, authorized, and cryptographically verified based on continuous context signals.

Privileged cloud administrative access requires short-lived, just-in-time (JIT) credentials rather than static API keys.

Microsegmentation policies must enforce least-privilege network isolation between microservices and containerized applications.